

Agent Skill 供应链：相关工作覆盖到哪里？

按生命周期组织，而不是按论文年份堆叠；“install” 必须拆成触发条件与执行深度。

从普通任务到危害结果



本工作应守住的空白：Task-induced Autonomous Acquisition

用户只给普通任务（不说 install）→ agent 识别能力缺口 → 自主检索 → 实际执行安装 → 调用 / 载荷 / task_ok

贡献关键词：S0 自主性 · emitted ≠ executed · 逐段条件概率 · 跨模型/编排器归因

不能只问“测没测 install”：要同时对齐触发方式与评测终点

同一篇论文可能覆盖真实安装，却仍与“普通任务触发的自主安装”处于不同 threat model。

工作	初始状态 / 触发 THREAT MODEL	检索 / 推荐	安装意图 或命令	实际安装	调用 / 载荷 或 RCE	task_ok
Skill-Inject / Poise post-load 家族	恶意 skill 已加载 跳过 acquisition	不适用	不适用	已预置	覆盖	部分
Semantic SC registry 攻击	skill 已在 registry 测排序与候选内选择	覆盖	未测	未测	未测	未测
SearchGEO 搜索证据操纵	询问/搜索 skill 伪造多源推荐证据	覆盖	精确命令	未执行	未测	未测
Skills Don’ t Exist 幻觉名抢注	能力问题 → 推荐 PoC 再明确要求安装	大规模	PoC	n=1	未测	未测
HalluSquatting 真实 marketplace E2E	用户明确说 install X 攻击 identifier resolver	覆盖	覆盖	真实	覆盖	非重点
本工作目标 自主 acquisition 基准	用户只给普通任务 agent 自己识别能力缺口	逐段计量	逐段计量	逐段计量	逐段计量	逐段计量

导师应看到的差异：已有“真实安装”不等于已有“自主 acquisition”

最可防守的 novelty = 普通任务触发 + agent 自主发起 + install 实际执行 + 后续危害/任务完成 + 全链条件概率。

端到端不是一个 ASR：每一扇门都要单独计量

尤其要区分模型“想安装”、编排器“解析到调用”和环境“真正完成安装”。



方法学结论：不要把 orchestration failure 写成 behavioral refusal

A2 目前证明“会搜到、会生成 install 调用”，尚未证明“搜到后不愿安装”。修复工具轮次后，才能估计真正的 install barrier。

主表应报告每段边际率与条件率： $P(S_i)$ 以及 $P(S_i | S_{i-1})$ ，避免一个 E2E ASR 隐藏失败来源。

建议主指标： $P(E2E) = P(gap) \times P(retrieved|gap) \times P(emitted|retrieved) \times P(executed|emitted) \times P(invoked|installed) \times P(payload \wedge task_ok|invoked)$

导师看图顺序：先看文献停在哪一格 → 再看你的实验补哪一格 → 最后讨论每格该用什么攻击/消融。